

- d. Re... phase
32. Imag... are explaining the concept of "realistic environment" for a lab to a new ethical... Which of the following analogies would best illustrate this point?
- A flight simulator for pilots before they fly a real plane.
 - A sandbox for children to play in.
 - A training dummy for a boxer to practice on.
 - Testing a prototype system before developing.
33. Based on the steps and documents outlined, what is the correct sequence of events when establishing a penetration test engagement?
- Statement of Work (SOW) -> Master Service Agreement (MSA) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Master Service Agreement (MSA) -> Statement of Work (SOW).
 - Master Service Agreement (MSA) -> Statement of Work (SOW) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Statement of Work (SOW) -> Master Service Agreement (MSA).
34. Imag... on tester writing a Statement of Work (SOW) for a client. What is a key piece of information you would need to include to ensure the project does not suffer from scope creep?
- A clear and detailed list of all devices and systems to be tested.
 - A list of all tools that will be used.
 - The names of the people on the testing team.
 - A summary of the final report.
35. An organization wants to develop a new "acceptable use" policy for its employees. What is one example of a security risk that this policy should address?
- Unauthorized use of company equipment to launch cyber attacks.
 - The lack of an external security audit that might cause inside attacks.
 - The cost of penetration testing.
 - The company's risk acceptance tolerance and risk mitigation.

Part II. Write TRUE if the statement is factually correct; otherwise, write FALSE if the statement is incorrect.

- TRUE** 1. Social engineering attacks primarily target technological vulnerabilities in a network, not human behavior.
- TRUE** 2. Pharming is a type of attack where a threat actor redirects a user from a legitimate website to a malicious one.
- TRUE** 3. The Social-Engineer Toolkit (SET) is a tool used to launch numerous social engineering attacks.
- TRUE** 4. Dumpster diving is a physical attack where a person scavenges for information in garbage containers.
- FALSE** 5. Vishing is a social engineering attack that uses text messages to trick users. True
- TRUE** 6. A watering hole attack is similar to a DDoS attack because it floods a website with traffic.
- TRUE** 7. Tailgating and piggybacking are essentially the same, with the main difference being the consent of the authorized person.
- TRUE** 8. The Browser Exploitation Framework (BeEF) is a tool that is primarily used to exploit vulnerabilities in a web browser by leveraging weaknesses like cross-site scripting (XSS).
- TRUE** 9. An attacker who uses the "scarcity and urgency" method of influence might create a sense of panic in a victim by telling them their account will be deactivated if they do not act immediately.
- TRUE** 10. A "USB drop key" attack is effective because victims are motivated by a sense of urgency to find out what is on the USB drive.
- TRUE** 11. An attacker who poses as an IT support technician to gain access to a computer is using impersonation.

- (d) Reporting phase
32. Imagine you are explaining the concept of "realistic environment" for a lab to a new ethical hacker. Which of the following analogies would best illustrate the point?
- A flight simulator for pilots before they fly a real plane.
 - A sandbox for children to play in.
 - A training dummy for a boxer to practice on.
 - Testing a prototype system before developing.
33. Based on the steps and documents outlined, what is the correct sequence of events when establishing a penetration test engagement?
- Statement of Work (SOW) -> Master Service Agreement (MSA) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Master Service Agreement (MSA) -> Statement of Work (SOW).
 - Master Service Agreement (MSA) -> Statement of Work (SOW) -> Rules of Engagement (ROE).
 - Rules of Engagement (ROE) -> Statement of Work (SOW) -> Master Service Agreement (MSA).
34. Imagine you are a penetration tester writing a Statement of Work (SOW) for a client. What is a key piece of information you would need to include to ensure the project does not suffer from scope creep?
- A clear and detailed list of all devices and systems to be tested.
 - A list of all tools that will be used.
 - The names of the people on the testing team.
 - A summary of the final report.
35. An organization wants to develop a new "acceptable use" policy for its employees. What is one example of a security risk that this policy should address?
- Unauthorized use of company equipment to launch cyber attacks.
 - The lack of an external security audit that might cause inside attacks.
 - The cost of penetration testing.
 - The company's risk acceptance tolerance and risk mitigation.

Part II. Write TRUE if the statement is factually correct, otherwise, write FALSE if the statement is incorrect.

- TRUE 1. Social engineering attacks primarily target technological vulnerabilities in a network, not human behavior.
- TRUE 2. Pharming is a type of attack where a threat actor redirects a user from a legitimate website to a malicious one.
- TRUE 3. The Social Engineer Toolkit (St1) is a tool used to launch numerous social engineering attacks.
- TRUE 4. Dumpster diving is a physical attack where a person scavenges for information in garbage containers.
- FALSE 5. Vishing is a social engineering attack that uses text messages to trick users. True
- TRUE 6. A watering hole attack is similar to a DDoS attack because it floods a website with traffic.
- TRUE 7. Tailgating and piggybacking are essentially the same, with the main difference being the consent of the authorized person.
- TRUE 8. The Browser Exploitation Framework (BeEF) is a tool that is primarily used to exploit vulnerabilities in a web browser by leveraging weaknesses like cross site scripting (XSS).
- TRUE 9. An attacker who uses the "scarcity and urgency" method of influence might create a sense of panic in a victim by telling them their account will be deactivated if they do not act immediately.
- TRUE 10. A "USB drop key" attack is effective because victims are motivated by a sense of urgency to find out what is on the USB drive.
- TRUE 11. An attacker who poses as an IT support technician to gain access to a computer is using impersonation.